

SECUREDEV & THREAT ANALYSIS PIPELINE – TEKNİK DOKUMANTASYON

1. Giriş ve Proje Kapsamı

Bu teknik dokümantasyon; 30 günlük staj programı süresince geliştirilen **SecureDev & ThreatAnalysis Pipeline** projesinin mimari tasarımını, kullanılan veritabanı şemalarını, API kullanım kılavuzunu, güvenlik kararlarını ve test senaryolarını kapsamaktadır. Proje, modern yazılım geliştirme yaşam döngüsünde (**SDLC**) güvenli kodlama standartlarının (Secure Coding) uygulanması, e-posta tabanlı siber tehditlerin otomatik analiz edilmesi ve kurumsal düzeyde log yönetimi ile korelasyon motorunun (**SIEM**) hayata geçirilmesini amaçlamaktadır.

2. Proje Mimarileri ve Veritabanı Şemaları

2.1. Sistem Mimarisi ve Modüler Dağılım

Proje ün ana sütun üzerine inşa edilmiş olup, her bir modül kendi alanında izole ve ölçeklenebilir bir mimariyle tasarlanmıştır:

- **Project1_SecureWeb (Güvenli Web API):**
 - **Mimari Altyapısı:** Katmanlı RESTful API mimarisi, Flask web çatısı üzerinde oluşturulmaktadır.
 - **Çalışma Prensibi:** İstemcilerden gelen http istekleri (Postman veya harici istemciler üzerinden), JWT (JSON Web Token) tabanlı kimlik doğrulama süzgecinden geçer. Rol Tabanlı Erişim Kontrolü (RBAC) mekanizması ile kullanıcının yetkileri doğrulanır. Yetkisiz erişim girişimleri ve kritik sistem olayları anlık olarak MSSQL veritabanına Audit Log olarak kaydedilir.
- **Project2_PhishingAnalysis (Oltalama ve Tehdit Analiz Aracı):**
 - **Mimari Altyapısı:** Modüler veri işleme hattı ve Streamlit tabanlı interaktif web arayüzü.
 - **Çalışma Prensibi:** Kullanıcı tarafından sisteme yüklenen ham “.eml” formatındaki e-posta dosyaları özel bir parser mekanizmasıyla ayrıştırılır. E-posta başlıkları (Headers) incelenerek SPF, DKIM ve DMARC uyumsuzlukları tespit edilir. Ek dosya (Attachment) içerikleri güvenli bir şekilde MD5/SHA256 kriptografik parmak izleriyle taranır ve ağırlıklı risk skorum algoritması (0-100 ölçeği) ile değerlendirilir.
- **Project3_SIEM_LogCorrelation (Çok Katmanlı SIEM ve Korelasyon Mantığı):**
 - **Mimari Altyapısı:** Çoklu iş parçacıklı (Multi-threaded) ağ dinleyicileri ve arka plan analiz motoru.
 - **Çalışma Prensibi:** Ağ katmanından gelen UDP (514) ve TCP (9998) syslog paketleri asenkron olarak dinlenir. Gelen loglar CEF (Common Event Format) standartlarına göre ayrıştırılarak MSSQL Logs tablosuna yazılır. Arka planda çalışan eşik tabanlı korelasyon motoru, belirli zaman aralıklarındaki anormal log hareketlerini (Örn: Brute Force denemeleri) tarayarak otomatik alarm üretir.

2.2. Veritabanı Şemaları (Microsoft SQL Server - SIEM_DB)

Sistemin veri katmanı, ilişkisel veritabanı bütünlüğü gözetilerek iki ana tablo üzerine oturtulmuştur:

- **Logs Tablosu:**
 - **LogID (INT, Primary Key, Identity):** Benzersiz log kayıt kimliği.
 - **Timestamp (DATETIME):** Logun ağdan yakalandığı veya sisteme düştüğü an.
 - **SourceProtocol (VARCHAR):** Verinin iletildiği protokol (UDP / TCP).
 - **SourceIP (VARCHAR):** Logu üreten kaynak cihazın IP adresi.
 - **RawLog (TEXT):** Üzerinde hiçbir değişiklik yapılmamış ham log verisi.
 - **ParsedData (NVARCHAR(MAX)):** CEF formatından çıkarılan yapılandırılmış anahtar-değer çiftleri (JSON).
- **Alarms Tablosu:**
 - **AlarmID (INT, Primary Key, Identity):** Benzersiz alarm kimliği.
 - **RuleName (VARCHAR):** Tetiklenen korelasyon kuralının adı.
 - **Severity (VARCHAR):** Tehdidin kritik seviyesi (High, Medium, Low).
 - **Source (VARCHAR):** Alarmı tetikleyen kaynak IP veya kullanıcı bilgisi.
 - **Description (TEXT):** Alarmin detaylı teknik açıklaması.
 - **CreatedAt (DATETIME):** Alarmin veritabanına işlendiği zaman damgası.

3. API Kullanım Örnekleri ve Güvenlik Kararları

3.1. API Kullanım Örnekleri (Project1_SecureWeb)

Geliştirilen güvenli uç noktaların test edilmesi ve harici servislerle entegrasyonu için kullanılan temel akışlar şunlardır:

- **Kimlik Doğrulama ve Token Üretimi**
 - **Açıklama:** Kullanıcı kimlik bilgileri doğrulanarak sisteme erişim anahtarı üretilir.
 - **Örnek JSON İstek Gövdesi:**

```
{
  "username": "bilal",
  "password": "sifre1234"
}
```
 - **Örnek Başarılı Yanıt (200 OK):**

```
{
  "access_token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9...",
  "role": "admin"
}
```

- **Korumalı Kaynak Erişimi (GET/ admin/ dashboard):**
 - **Açıklama:** Header alanına Authorization: Bearer <token> eklenerek gerçekleştirilir.
 - **Hata Durumları:** Token içermeyen istekler 401 Unauthorized; yetkisiz rol ile yapılan erişim denemeleri ise 403 Forbidden yanıtı döndürür ve Audit Log mekanizması tarafından kayıt altına alınır.

3.2. Alınan Kritik Güvenlik Kararları (Secure Coding & OWASP Standartları)

Proje geliştirme sürecinde endüstri standardı güvenlik prensipleri sıkı bir şekilde uygulanmıştır:

- **Parola Hashleme (Credential Security):** Kullanıcı parolaları veritabanında asla düz metin (plaintext) olarak saklanmamıştır; bcrypt algoritması ve dinamik tuzlama (salt) yöntemiyle hashlenmiştir.
- **Rol Tabanlı Erişim Sınırlandırması (RBAC):** Yetki yükseltme zafiyetlerini önlemek amacıyla API uç noktalarında dekoratör tabanlı rol denetimleri zorunlu tutulmuştur.
- **Güvenli Dosya İşleme:** Oltalama analiz modülünde incelenen e-posta ekleri hiçbir şekilde sandbox veya ana sistem ortamında çalıştırılmamış, sadece statik hash (MD5/SHA256) ve imza analizi ile sınırlandırılmıştır.
- **Güvenli Hata Yönetimi:** Son kullanıcılara veritabanı sorgularını veya iç mimari detaylarını ifşa eden hata dökümleri (Stack Trace) gösterilmemiş, standartlaştırılmış HTTP durum kodları ile güvenli hata yönetimi sağlanmıştır.

4. Bilinen Eksiklikler, Test Senaryoları ve Kurulum Kılavuzu

4.1. Bilinen Eksikler ve İyileştirme Potansiyelleri (Known Limitations)

- **Merkezi Olmayan Dağıtık Log Toplama:** Mevcut mimaride UDP/TCP dinleyiciler tek bir sunucu üzerinde konumlandırılmıştır; yüksek ölçekli yapılarda Logstash veya Fluentd ajan mimarileriyle genişletilebilir.
- **Yüksek Hacimli Log Optimizasyonu (High-EPS):** Çok yoğun ağ trafiğinde anlık korelasyon motoru yükünü dengelemek adına MSSQL indeksleme ve önbellekleme katmanları gelecekte entegre edilebilir.

4.2. Doğrulama ve Test Senaryoları (Test Scenarios)

1. **Brute Force Atak Simülasyonu:** udp_tester.py otomasyon betiği ile kısa zaman aralığında çok sayıda başarısız oturum açma logu üretilmiş, eşik değerinin aşılmasıyla birlikte **Alarms** tablosuna başarılı bir şekilde "**Brute Force**" kaydının düştüğü doğrulanmıştır.
2. **Yetkisiz Yetki İhlali Testi:** Postman aracılığıyla **User** rolüne sahip bir token ile **Admin** paneline erişim denenmiş, sistemin başarılı bir şekilde **403 Forbidden** döndürdüğü ve durumu logladığı teyit edilmiştir.

4.3. Hızlı Kurulum ve Dağıtım Adımları (Deployment Guide)

Sistemi lokal veya test ortamında ayağa kaldırmak için şu adımlar izlenir:

- **Docker Konteyner ile Çalıştırma:**

```
docker-compose up --build
```

- **Manuel Kurulum Adımları:**

1. Gerekli Python kütüphanelerini yükleyin: **pip install -r requirements.txt**
2. ODBC sürücülerini ve MSSQL bağlantı parametrelerini **db_conn.py** üzerinden yapılandırın.
3. Servisleri ilgili dizinlerden çalıştırın (**python app.py** ve **streamlit run app.py**).